

Tab 1

**Architecting Agentic Cyber Defense:
Training AI Agents in Digital Twins to Act Before Attack**

Graham J. Westbrook

University of Oxford

Saïd Business School // AI for Business Cohort

8 June 2025

Word Count (excluding references): 2,618

Acknowledgements:

I acknowledge the use of ChatGPT 4.0 (OpenAI, <https://chat.openai.com>) to clarify concepts and help with structure, image creation, and citations in APA format.

Architecting Agentic Cyber Defense: Training AI Agents in Digital Twins to Act Before Attack

A vast majority of global cybersecurity leaders¹ expect and feel prepared for a sophisticated cyber attack in the next twelve months, yet only a third regularly simulate attack scenarios to validate and optimize their security defenses (Proofpoint, 2024; Pentera, 2025). Without the ability to implement security optimizations before an attack happens, leaders are positioned merely to react to cyber threats, giving adversaries an advantage and increasing the likelihood of breach, extortion, and cyber-kinetic harm to humans.

This discussion centers on how to operationalize cyber security defenses before a breach without compromising security posture. I explore the limits of human cybersecurity decision-making, advocate for the use of realistic simulation, and propose training AI agents in simulation testbeds – or digital twins – to adaptively optimize before an attack succeeds in a production network environment. Competitive advantage will be achieved among cybersecurity vendors who successfully leverage reinforcement learning algorithms to navigate this novel shift from slow, reactive, human governance to continuous, preemptive, AI-driven cyber defense.

Cybersecurity (Re-)Actions

Securing an organization from cyber threats has traditionally been a uniquely human decision-making process. Chief Information Security Officers have been responsible for understanding cyber threats, measuring risk, procuring tools, hiring defenders, and enforcing policy to protect the organization. Knowledgeable CISOs have made evidence-based and data-driven decisions by first understanding their attack surface then deploying the right people, process and technology toward the problem. For example, a CISO will have understood the most vulnerable areas of a production network – often called cyber key terrain – and deployed security agents² to detect and mitigate threats alongside a log aggregation platform to collect findings and gain visibility.

In recent years, detection engineering has emerged as a discipline under the purview of the CISO to increase the speed by which organizations detect threats, using cyber threat

¹ 70% of Chief Information Security Officers across Global 2000 organizations expect an attack, and ~57% feel prepared for it. Only 37% validate with breach and attack simulations, and even fewer with trusted metrics.

² e.g. EDR, HRM, UEBA, VRM

intelligence³ to inform detection logic.⁴ However, even this remains largely a human pursuit, despite happening at a more tactical level and “shifting left”⁵ in the organization's software development life cycle and cyber kill chain. Detection engineers still consume written intelligence reports and hand-craft new queries to find and eliminate threats (Joshua, 2025). Despite being assisted by AI Large Language Models for constructing detection logic and detecting threats faster (~minutes or days vs. days or weeks with threat hunting and other traditional approaches), the time savings between decision and action remains unrealized.

Data examples used to inform such decisions and detections across strategic, operational and tactical levels include:

- ***Threat Intelligence Reports (Strategic)***. *Structured reporting on cyber attacks and cyber threat landscapes, often associated with Tactics, Techniques & Procedures (TTPs) and Indicators of Compromise (IOCs) of cyber threat actors, cyber-criminal, and nation state.*
- ***SOC Dashboards (Operational)***. *Security Operations Center findings derived from security tool telemetry and logs.*
- ***Sigma Rules or Splunk Processing Language (SPL) Queries (Tactical)***. *YAML, JSON or custom queries used to search for malicious or suspicious activity within networks.*

Historically, if experiencing a severe attack from a sophisticated adversary, the CISO formed a war room, directed action to ‘threat hunt,’ and deployed resources toward the problem. But this process is slow. There is no way the CISO or responsible defender could have comprehended everything happening in the network and made decisions fast enough to eliminate the threat as it unfolded. By the time the incident response was underway, all human decisions and actions were merely *reactions*.

In most organizations, there are billions of data points everyday upon which to make rapid cybersecurity decisions and policy changes (Sjouwerman, 2023). But given everything hinges upon the constant evolution of the threat, human decision-makers cannot even keep pace let alone improve future outcomes. Humans simply react.

³ Advanced knowledge of the adversary used to reduce uncertainty in decision-making.

⁴ The rules security tools use to find evidence of malice

⁵ “Shift left” or “left of bang” in security refers to catching a cyber threat earlier in the typical flow of events, often referred to as the “cyber kill chain.”

A Philosophy for Architecting Agentic Cyber Defense

If a “machine” were to replace a CISO’s reactive decision-making and policy enforcement, it would need to prove itself faster, smarter and more actionable than a human without compromising the security of a production network (Brynjolfsson & McAfee, 2017). However, there are very few tools on the market, if any, capable of this kind of trusted speed, intelligence and preemptive action unless first validated in a non-production environment, without threatening confidentiality, integrity or availability (Voas, Mell, Laplante, & Piroumian, 2025).

Cue a digital twin.⁶ In cybersecurity, a digital twin is a representative, non-production computer network environment with synthetic data that replicates reality – or an approximation of reality – with enough fidelity to facilitate meaningful simulations of dangerous scenarios (Voas, Mell, Laplante, & Piroumian, 2025). This environment allows a CISO to simulate a severe and destructive cyber attack as many times as necessary to prepare people, process and technology before something bad happens in a production network.

A novel approach in the industry would be to extend the digital twin not just to simulate various cybersecurity futures but to train AI agents with reinforcement learning to adaptively defend and act preemptively. This would require emulating not only the underlying terrain⁷ but also simulating realistic data,⁸ security tools and defenders, constructed alongside an AI framework and agent model(s) capable of learning from itself and pushing optimizations to production.

Organizations have long talked about moving from reactive to proactive or predictive (Forbes, 2025). Organizations have rarely talked of moving to preemptive action: taking defensive action before a threat action happens against it. In the age of AI, a solution like this demands to be evaluated, but remains blocked by creativity and strategic thinking, much like innovations in arithmetic could not be immediately conceptualized by humans but later formed the basis for modern computing; predictive machine learning applications lag behind creative inspiration (Agrawal, Gans, & Goldfarb, 2018).

To inspire innovation, the author proposes an architecture similar to the following:

1. Environment Simulation

⁶ Also, called a “cyber range.” If less sophisticated, “dev environment,” “testbed” or “sandbox.”

⁷ Information technology (IT), Operational Technology (OT), Internet of Things (IoT) & Cloud

⁸ Comprised of non-personally identifiable User Emulation and realistic Attack Emulation

- High-fidelity digital twin modeling IT, OT, IoT & Cloud⁹ terrain;

2. Monitoring Tools

- Commercial or Open-Source security tooling to collect & disseminate network telemetry;

3. Synthetic Data

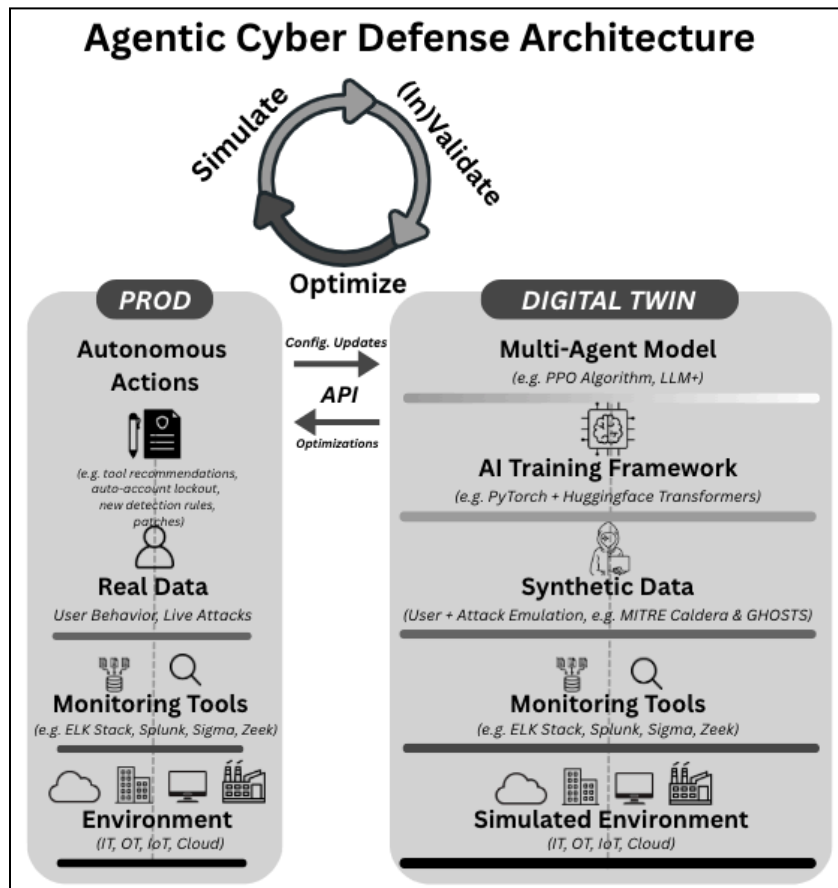
- Realistic, non-personally identifiable user, network, defender and attack emulation, which themselves may be AI agents;

4. AI Framework

- Management of AI Model training and pre-trained model transformers for cybersecurity specific detail and log analysis;

5. Agent Model

- AI Model training (e.g. RL PPO reinforcement learning algorithm + LLMs for interpreting threat intelligence, security logs and detection logic).



Said simply, the environment facilitates a closed-loop system which continuously simulates → (in)validates → optimizes defense responses to cyber attack emulations and trains a defensive AI agent without impacting a production network (Schöning, Riechmann, & Pfisterer, 2022). A Reinforcement Learning algorithm on top of the environment is critical to derive

⁹ Information Technology, Operational Technology (ICS/SCADA), Internet of Things & Cloud Computing

strategic AI-driven recommendations and defensive optimizations. RL is the best type of machine learning for this type of environment because it operates well within simulation environments, does not require labeled data, and is incentivized for long-term learning by way of its reward system (Sutton & Barto, 2018). The trade-offs with its relatively unstructured autonomy, however, are that it can be relatively expensive and require thousands of different scenarios to properly identify and “reward” meaningful outcomes (Sutton & Barto, 2018).

Examples of practical actions which could be taken or reverted autonomously by a cyber defense agent include:

- **Updating detection logic.** Simulated-validated detection rules successfully identifying malice without harming the environment, thus safe enough to update security tools;
- **Recommending a new cybersecurity tool.** Commercial tools compared against each resulting in significant security improvement and cost savings in simulation;
- **Taking defensive action.** Locking a user account after predicting anomalous insider threat behavior; Auto-deploying a patch for a 0-day vulnerability not yet exploited in production.

A leading algorithm which would likely be best for this type of engagement is Proximal Policy Optimization, primarily because it does not implement changes that are too large, nor does it increase sample inefficiency within multi-agent environments (Yu et al., 2021). It is essentially always asking itself: is this iteration from baseline better than the expected? If so, learn, and update the baseline safely and slowly; If not, ignore or avoid.

Despite not using standard RL nomenclature, the author proposes an understandable, conceptual formula to visualize the algorithm¹⁰ is as follows:

$$y = \beta_i + \alpha \cdot (\hat{y} - \bar{y})$$

... where:

- y_{actual} = the cyber defense optimization taken in production
- β = the current policy or baseline
- i = the number of learning steps so far
- α = the controlled learning rate (e.g. how fast or aggressive baseline can change)
- $\hat{y}_{predicted}$ = the model’s predicted next best action

¹⁰ Traditional RL models would use different variable notation: $\theta_{i+1} = \theta_i + \alpha \cdot A(st, at)$

- $\bar{y}$ *expected* = the expected action before update or optimization

A meaningful delta between predicted and expected y results in a highly rewarded – and thus recommended – actual action.

Preemptive Optimization Value Hypothesis: Act Before Attack

Cybersecurity vendors are constantly battling for differentiation because organizations will pay a premium for the best solution to protect trade secrets, innovations and customer information against theft and disclosure. Due to the nature of the evolving cyber threat landscape¹¹ solutions often lag behind adversaries' ability to adapt and attack. The only way organizations will keep pace with or outpace threats is to accelerate decision-making optimizations. At scale, this means that a RL-driven agent training architecture facilitating safe response to previously unknown threats¹² would be in high demand and provide rapid competitive advantage.

Few solutions – if any – are capable of continuous preemptive cyber defense like this on the market today. Adjacent examples are AI-enabled XDR solutions, Llama Guard and Microsoft Purview. But with over-focus on production environments (without state-of-the-art synthetic data and attack emulation), their reinforcement learning horizons are currently limited and mainly focused on endpoint action, or policy enforcement and governance. The proposal featured in this discussion aims for a differentiated, novel cyber defense architecture for adaptive optimization that does not stop at policy but encourages any security actions. This new domain is known as preemptive cyber defense and is emerging as a primary theme among CISOs (Gartner, 2024).

RL algorithms like PPO applied toward this philosophy will create a technological and economic moat for leading cybersecurity vendors who get it right. Those with the most cutting edge synthetic data inputs simulated in the most realistic environment with the best RL algorithms will achieve advantage faster and more completely. Forward-thinking use of “neural networks to learn reward functions” to “adjust in real-time” like Self-Rewarding Deep Reinforcement Learning, or SRDRL, will be fastest to market dominance (Huang, Zhou, Zhang, & Lu, 2024). Multi-agent environments may even be able to do scenario analysis for previously inconceivable attack or behavior emulations, thereby simulating the future.

¹¹ An industry standard term for describing the ecosystem of malicious hackers and nation-state threat actors targeting organizations for financial gain, espionage or inflicting harm.

¹² Often called ‘0-days’ because the organizations have had zero days to evaluate a response.

To quantify the magnitude of competitive advantage, we can estimate market penetration of leading solutions into the Global 2000 based on projected return on investment. Meaning, the more valuable the solution to an ideal customer, the more likely success a cybersecurity vendor will have in the market. Assuming an average security budget for a Global 2000 organization is USD 50M¹³ per year, and given frequently cited areas of concern among CISOs, a conservative estimate of ROI includes:

- **Better detection logic and false positive reduction.** Forrester (2024) found that a leading AI response agent reduced false positives by 79%. The efficiency savings realized by reducing the amount of time, money and energy people and technology spend chasing ghosts (read: false positives) is enormous.
- **Procuring tools with predicted faster time-to-value or consolidating existing.** CISOs are often evaluating technologies against a very clear set of criteria, and can save USD millions by benchmarking tools against each other and procuring more cost effective solutions, while reducing spend on and sprawl of existing tools (Gartner, 2022).
- **Incident and breach avoidance.** Companies spend USD ~6M recovering per data breach, including fines, legal fees, reputation loss, and remediation (IBM, 2024). If a cyber defense agent blocks malicious activity before a breach, that could be an annualized multiple of \$6M x number of incidents per year. Ransomware downtime, alone, on average costs USD 125K per hour (IBM, 2024).

Explainability Remains with the CISO

The value and ubiquity of AI-driven decision-making is undeniable: nearly 9 in 10 CISOs will adopt defensive AI/ML solutions this year (Proofpoint, 2024). But a key decision-making suite that will not easily be replaced by machines is security strategy and investment. The CISO serves an eminently human role in the organization by acting as responsibility-in-chief for cybersecurity outcomes, reporting to the CEO & Board in a manner which demands explainability of intent, transparency of action, and justification of spend.

Today, trust is still a characteristic primarily reserved for humans and will not be something easily replaced with innovative algorithms; even good ones. The reality is that “AI involves tradeoffs: more speed, less accuracy; more autonomy, less control; more data, less privacy” (Agrawal, A., Gans, J., & Goldfarb, A., 2018, p.3). Where a human displays

¹³ Likely conservative estimate, given that many of the Fortune 100 are in the USD hundreds of millions

uncertainty, Agrawal, Gans, Goldfarb (2018) remind us that machines blindly reassure. Where a human empathizes with potential workforce impact, machines feel nothing (Shadbolt & Hampson, 2024). Where a human discerns prudent investments, machines project (Shadbolt & Hampson, 2024).

If the RL algorithm in the cyber defense architecture needs to be retrained, one way to mitigate risk is to keep a human-in-the-loop, which can recommend improvements, increase explainability, and even help conduct Inverse Reinforcement Learning – or IRL – by having the AI learn from its expert human behavior rather than the other way around (Bertsimas, O’Hair, & Pulleyblank, 2016).

For many years to come, CISOs will be called upon to set strategy in light of their experiential knowledge and sweat equity while looking into the eyes of another human leader. And they alone will be entrusted with financial capital for security investment. As AI models become increasingly unexplainable in their operations or conclusions, humans will remain accountable for explanation and the pursuit of truth (Floridi & Cowls, 2022).

Addressing Negative Externalities

While many benefits emerge from accelerating decision strategy in defense using machine learning, potential negative externalities are not trivial and pitfalls abound.

Constructing representative digital twins, for example, depends on accurate asset discovery, a notoriously difficult task (Boyson, 2014). An over-correction into simulation technologies may result in a swing from one false sense of security (naivete) to another (impenetrability). Conversely, over-reliance on digital twin environments may skew understanding of reality or even lead to omitted variables and improper sample selection.

One which warrants extended discussion is that of defensive agents getting so good at defending that they replace human defenders entirely. Job displacement is a real AI-induced problem with deep economic and social repercussions.

Security leaders and cybersecurity vendors alike must go to great lengths to evaluate potential implications caused by investing in faster outcomes. Reality, after all, is much less forgiving than perception. However, many years of ‘security through obscurity’ has proven itself insufficient in dealing with the demands of an ever-evolving threat landscape: one in which cyber criminals use the same technology – known as adversarial AI – to explore malicious

applications and facilitate cyber-kinetic breakout of attacks harming real world operational technology, like water treatment centers or power plants (US Department of Homeland Security, 2024).

Never has the difference between feeling prepared and being prepared been so important in cyber defense. After an honest mitigation of pitfalls and negative externalities – security leaders must employ a philosophy like *simulate* → *validate* → *optimize* to reduce uncertainty in cybersecurity defense and protect human life else forever remain in a version of the latin maxim: *Videri quam Esse*; to seem, rather than to be.

References

- Agrawal, A., Gans, J., & Goldfarb, A. (2018). *Prediction machines: The simple economics of artificial intelligence*. Harvard Business Review Press.
- Bertsimas, D., O'Hair, A. K., & Pulleyblank, W. R. (2016). *The analytics edge*. Dynamic Ideas.
- Boyson, S. (2014). Cyber supply chain risk management: Revolutionizing the strategic control of critical IT systems. *Technovation*, 34(7), 342–353. <https://doi.org/10.1016/j.technovation.2014.02.001>
- Brynjolfsson, E., & McAfee, A. (2017, July 18). *The business of artificial intelligence*. Harvard Business Review. <https://hbr.org/2017/07/the-business-of-artificial-intelligence>
- Floridi, L., & Cowls, J. (2022). *A unified framework of five principles for AI in society*. Harvard Data Science Review, 4(1). <https://doi.org/10.1162/99608f92.8cd550d1>
- Forbes. (2025). How CISOs Will Navigate The Threat Landscape Differently In 2025. *Forbes Magazine*. <https://www.forbes.com/councils/forbestechcouncil/2025/03/04/how-cisos-will-navigate-the-threat-landscape-differently-in-2025>
- Forrester. (2024). *The Total Economic Impact Of Microsoft Sentinel*. TEI Report. https://tei.forrester.com/go/microsoft/microsoft_sentinel
- Gartner (2022). *Gartner Survey Shows 75% of Organizations Are Pursuing Security Vendor Consolidation in 2022*. <https://www.gartner.com/en/newsroom/press-releases/2022-09-12-gartner-survey-shows-seventy-five-percent-of-organizations-are-pursuing-security-vendor-consolidation-in-2022>
- Gartner. (2024). *Emerging Tech: Adoption Trends in Preemptive Cyber Defense*. <https://www.gartner.com/en/documents/5912075>
- Huang, Y., Zhou, C., Zhang, L., & Lu, X.-P. (2024). *A self-rewarding mechanism in deep reinforcement learning for trading strategy optimization*. *Mathematics*, 12(24), 4020. <https://doi.org/10.3390/math12244020>
- IBM. (2024). Cost of a Data Breach Report 2024. <https://www.ibm.com/reports/data-breach>
- Joshua, I. (2025). *Threat research is broken – security teams need automation now*. Cyber Defense Magazine. <https://www.cyberdefensemagazine.com/threat-research-is-broken-security-teams-need-automation-now>
- Pentera. (2025). *The State of Pentesting 2025*. Survey Report. <https://pentera.io/wp-content/uploads/2025/05/2025-state-of-manual-pentesting-survey-report.pdf>

Proofpoint, Inc. (2024). *Voice of the CISO Report 2024*. Survey Report.

<https://nationalcioreview.com/wp-content/uploads/2024/06/pfpt-us-wp-voice-of-the-CISO-report.pdf>

Schöning, J., Riechmann, A., & Pfisterer, H.J. (2022). AI for Closed-Loop Control Systems: New Opportunities for Modeling, Designing, and Tuning Control Systems. *arXiv*. <https://arxiv.org/abs/2201.06961>

Shadbolt, N., & Hampson, R. (2024). *As if human: Ethics and artificial intelligence*. Yale University Press.

Sjouwerman, S. (2023, March 21). *Why organizations need a data-driven cybersecurity strategy*. Forbes Technology Council.

<https://www.forbes.com/sites/forbestechcouncil/2023/03/21/why-organizations-need-a-data-driven-cybersecurity-strategy>

Sutton, R. S., & Barto, A. G. (2018). *Reinforcement learning: An introduction* (2nd ed.). MIT Press.

<https://web.stanford.edu/class/psych209/Readings/SuttonBartoIPRLBook2ndEd.pdf>

U.S. Department of Homeland Security. (2024, November 14). *Roles and responsibilities framework for artificial intelligence in critical infrastructure*.

<https://www.dhs.gov/publication/roles-and-responsibilities-framework-artificial-intelligence-critical-infrastructure>

Voas, J., Mell, P., Laplante, P., & Piroumian, V. (2025). *Security and trust considerations for digital twin technology* (NIST Interagency/Internal Report 8356). National Institute of Standards and Technology.

https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=957183

Yu, C., Velu, A., Vinitzky, E., Gao, J., Wang, Y., Bayen, A., & Wu, Y. (2021). The Surprising Effectiveness of PPO in Cooperative Multi-Agent Games. *arXiv*. <https://arxiv.org/abs/2103.01955>